IES

Francisco de

Goya Curso

2026-2027

Seguridad y Alta Disponibilidad

2 – Seguridad Lógica

Contenido

1. Objetivos....3
2. Introducción....3
La correcta instalación y configuración del software de seguridad son procesos críticos
....
4
2.1 Fases de un ataque informático....4
2.2 Medidas de seguridad....5
3. Política de contraseñas....7
1. Requisitos de Contraseñas....7
2. Almacenamiento de Contraseñas....8
3. Autenticación de Dos Factores (2FA)....8
4. Cambio de Contraseñas Olvidadas....9
5. Auditoría y Cumplimiento....9
6. Educación y Concienciación....9
7. Cumplimiento Legal y Normativo....9
8. Respuesta a Incidentes....9
9. Políticas Específicas por Nivel de Acceso....9

1. Objetivos

- **Reconocer las fases de un ataque** y las medidas de seguridad que se pueden tomar.
- **Conocer las diferentes políticas** de seguridad que una empresa debe establecer:contraseñas, copias de seguridad, almacenamiento, etc.
- **Distinguir entre los distintos métodos de protocolos de autenticación y autorización**.Listas de control de accesos (ACL).
- **Entender la diferencia entre los distintos tipos de copia de seguridad**, cómo se realizan y cómo se restauran.

Mapa conceptual



2. Introducción

Garantizar la seguridad de un sistema informático es una tarea esencial en el entorno digital actual. **La instalación, configuración y actualización adecuadas del software de seguridad son pilares fundamentales para mantener la integridad y la confidencialidad de los datos y la del sistema informático.** La elección del software de seguridad debe basarse en una evaluación exhaustiva de las amenazas potenciales que enfrenta el sistema, ya que diferentes tipos de ataques, como malware, intrusiones y ataques cibernéticos, requieren enfoques específicos de protección. Además, es crucial que esta selección sea respaldada por políticas de seguridad sólidas y buenas prácticas de gestión de riesgos, que guíen la implementación de medidas efectivas de protección.

La correcta instalación y configuración del software de seguridad son procesos críticos que deben llevarse a cabo con atención meticulosa a los detalles. La falta de configuración adecuada o la omisión de actualizaciones pueden dejar al sistema vulnerable a amenazas conocidas o incluso desconocidas. Además, la educación y la concienciación de los usuarios finales sobre prácticas seguras son igualmente esenciales para mitigar riesgos, ya que incluso el software de seguridad más avanzado no puede ser completamente efectivo si los usuarios no están informados y no siguen las mejores prácticas de seguridad digital.

En resumen, **la seguridad informática es un proceso en constante evolución** que requiere una inversión continua en tecnología y en la capacitación y concienciación de las personas para proteger adecuadamente los sistemas y los datos en un mundo digital cada vez más interconectado.

2.1 Fases de un ataque informático

Los ataques informáticos suelen constar de varias fases, cada una diseñada para alcanzar un objetivo específico dentro del proceso global del ataque. Aquí están las fases típicas de un ataque informático:



1. **Reconocimiento (Reconnaissance)**: En esta fase inicial, los atacantes recopilan información sobre el objetivo. Esto puede incluir la identificación de sistemas y servicios en la red, la búsqueda de vulnerabilidades conocidas y la recopilación de datos sobre empleados u otros aspectos de la organización. Los atacantes pueden utilizar técnicas como la exploración de puertos, la búsqueda de información pública y la recolección de datos de redes sociales.

2. **Escaneo y Enumeración (Scanning and Enumeration):** En esta etapa, los atacantes intentan identificar sistemas y servicios específicos que puedan ser vulnerables. Utilizan herramientas y técnicas para recopilar información más detallada sobre la red, como la detección de sistemas operativos y la identificación de puertos abiertos. Esta fase ayuda a los atacantes a reducir su enfoque a posibles puntos de entrada.

3. **Ganar Acceso (Gaining Access):** Una vez que los atacantes han identificado posibles vulnerabilidades o puntos de entrada, intentan explotarlos para obtener acceso no autorizado a sistemas o redes. Esto puede lograrse mediante la explotación de vulnerabilidades de software, el uso de contraseñas débiles o robadas, el phishing u otras técnicas de ingeniería social.

4. **Mantenimiento de Acceso (Maintaining Access)**: Después de obtener acceso, los atacantes buscan mantener su presencia en el sistema objetivo. Esto puede incluir la

instalación de puertas traseras (backdoors), la creación de cuentas de usuario adicionales o la manipulación de registros para ocultar su actividad.

4.1 *Movimiento Lateral (Lateral Movement):* En esta fase, los atacantes intentan expandir su acceso a otros sistemas o áreas de la red. Pueden usar credenciales robadas o técnicas de escalada de privilegios para moverse de un sistema comprometido a otro dentro de la organización.

4.2. *Recopilación de Datos (Data Exfiltration)*: Si el objetivo del ataque es robar información, los atacantes recopilan y filtran datos sensibles de la red comprometida. Pueden utilizar métodos cifrados o técnicas de ocultación para evitar la detección.

5. **Encubrimiento y Eliminación de Huellas** (Covering Tracks): Después de completar sus objetivos, los atacantes intentan encubrir su presencia y actividades en el sistema comprometido. Esto puede incluir la eliminación de registros de actividad y la reversión de cambios realizados.

6. **Ataques Posteriores (Post-Exploitation):** Algunos ataques pueden involucrar fases adicionales, como el establecimiento de persistencia a largo plazo en la red, la preparación para futuros ataques o la expansión de la operación maliciosa a nivel global.

Es importante destacar que estos pasos no son lineales y pueden variar según el tipo de ataque y el objetivo del atacante. **Las organizaciones deben implementar medidas de seguridaden cada fase para detectar y mitigar amenazas antes de que causen daños significativos.** La ciberseguridad efectiva implica una combinación de tecnología, capacitación y concienciación del personal, y una respuesta rápida y coordinada ante incidentes.

2.2 Medidas de seguridad

La seguridad en sistemas informáticos es una preocupación fundamental para proteger la integridad, la confidencialidad y la disponibilidad de la información y los recursos. Las principales medidas son las siguientes:

1. **Política de contraseñas:** Es un conjunto de reglas y directrices que una organización o entidad establece para el uso seguro y eficaz de contraseñas en sus sistemas y recursos informáticos. El objetivo principal de una política de contraseñas es mejorar la seguridad al garantizar que las contraseñas sean lo suficientemente robustas para resistir ataques y alentar a los usuarios a mantener prácticas.
2. **Listas de control de accesos** (ACL, por sus siglas en inglés, Access Control List)

es una herramienta de seguridad utilizada en sistemas informáticos y de redes para

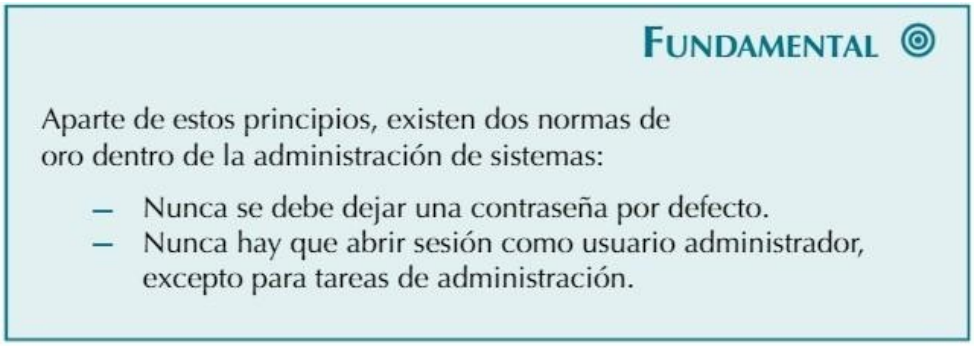
gestionar y controlar quién tiene permiso para acceder a recursos o realizar ciertas acciones en un sistema. Las ACL se utilizan para garantizar la seguridad y proteger los activos de una organización.

3. **Criptografía.** La criptografía es una de las medidas de seguridad más fundamentales y efectivas en el mundo de la tecnología de la información y la seguridad cibernética. Implica el uso de algoritmos matemáticos y técnicas para convertir información en un formato ilegible (cifrado) que solo puede ser descifrado por aquellos que tienen la clave de descifrado adecuada.
4. **Política de almacenamiento.** Dicha política dependerá del rendimiento, disponibilidad y accesibilidad requeridos por un sistema informático.
5. Políticas de copias de seguridad.
6. **Protección ante software malicioso (malware).** Antivirus, protección contra spam, ataques diversos, etc.
7. **Securización del sofware utilizado.** Actualización y parches de seguridad.
8. **Seguridad perimetral.** Cortafuegos, proxies o VLAN.
9. **Alta disponibilidad**. Implantación de servicios redundantes que entran en funcionamiento según las necesidades de uso.

3. Política de contraseñas

Las contraseñas (o credenciales) son una medida de seguridad fundamental en la informática . Sirven para varios propósitos esenciales relacionados con la protección de la información y el acceso a sistemas y cuentas. Su principal uso es la **Autenticación de Usuarios**. Cuando un usuario proporciona la contraseña correcta, el sistema tiene una forma de asegurarse de que la persona que está intentando acceder es quien dice ser. Por eso la importancia de que sean personales e intransferibles. No deberían compartirse por varios usuarios.

Las contraseñas también pueden ser utilizadas por **procesos** o programas que acceden de forma automática.



Una política de contraseñas es un conjunto de reglas y directrices que una organización establece para garantizar que las contraseñas utilizadas por sus usuarios y empleados sean seguras y cumplan con los estándares de seguridad. Una política de contraseñas efectiva es esencial para proteger los sistemas y los datos de una organización contra amenazas. Una estructura básica de una política de contraseñas que puedes adaptar a las necesidades específicas de tu organización sería la siguiente:

1. **Requisitos de Contraseñas**:
   - Longitud mínima: Establece una longitud mínima para las contraseñas (por ejemplo, al menos 12 caracteres).
   - Caracteres requeridos: Especifica que las contraseñas deben incluir una combinación de letras mayúsculas, minúsculas, números y caracteres especiales.
   - Prohibición de contraseñas comunes: Prohíbe el uso de contraseñas comunes y fáciles de adivinar (por ejemplo, "123456" o "password").
   - Cambios periódicos: Establece la frecuencia con la que los usuarios deben cambiar sus contraseñas (por ejemplo, cada 90 días).
   - Historial de contraseñas: Evita que los usuarios reutilicen contraseñas anteriores.

2. Almacenamiento de Contraseñas:

- Almacenamiento seguro: Indica que las contraseñas deben almacenarse de forma segura utilizando técnicas de cifrado y hashing para protegerlas de accesos no autorizados.
- No compartir contraseñas: Prohíbe a los usuarios compartir sus contraseñas con otros usuarios o escribirlas en lugares públicos.

3. Autenticación de Dos Factores (2FA):

- Fomenta el uso de la autenticación de dos factores (por ejemplo, un token, un teléfono móvil, un USB, un llavero) siempre que sea posible, especialmente para cuentas que acceden a información sensible.



U2F (Universal 2nd Factor). Es un estándar abierto de autenticación que permite a los usuarios de internet el acceso seguro a múltiples servicios online con una única llave de seguridad.

Desarrollado por Google y Yubico, ha sido adaptado por muchas grandes empresas como Facebook, Gmail, Amazon, etc. La última generación del protocolo U2F se llama **FIDO2**.

A grandes rasgos, U2F proporciona un marco con soporte para múltiples sistemas de autenticación. Las posibilidades son muchas, al incorporar desde el uso de características biométricas (lectores de huellas o de iris, procesamiento de la voz, reconocimiento facial, etc) a la utilización de dispositivos hardware de seguridad (dongles).



https://fidoalliance.org/content/video/

4. **Cambio de Contraseñas Olvidadas:**
   - Define un procedimiento seguro para que los usuarios restablezcan sus contraseñas en caso de olvido, que incluya una verificación adecuada de la identidad del usuario.

5. **Auditoría y Cumplimiento:**
   - Establece un proceso para realizar auditorías periódicas de las contraseñas y asegúrate de que los usuarios cumplan con los requisitos establecidos en la política.

6. **Educación y Concienciación:**
   - Proporciona capacitación regular a los usuarios sobre buenas prácticas de gestión de contraseñas y sobre cómo reconocer y evitar el phishing.

7. **Cumplimiento Legal y Normativo:**
   - Asegúrate de que la política de contraseñas cumpla con todas las regulaciones y leyes de seguridad aplicables en tu industria o ubicación geográfica.

8. **Respuesta a Incidentes:**
   - Describe cómo actuar en caso de una violación de seguridad relacionada con contraseñas, incluyendo la notificación de incidentes y la recuperación de cuentas comprometidas.

9. **Políticas Específicas por Nivel de Acceso:**
   - Para cuentas de administrador u otros roles con acceso crítico, considera implementar requisitos de contraseñas más estrictos.

Una política de contraseñas sólida es esencial para proteger contra el acceso no autorizado y las violaciones de datos. Además de establecer la política, es importante educar a los usuarios sobre su importancia y promover prácticas de seguridad cibernética en toda la organización.

Realiza la práctica 1 del aula virtual de uso de *libpam_cracklib*

Realiza la práctica 2 del aula virtual de uso de *aplicación 2FA*